

# O incidente que parou a linha

Missão: reconstruir uma linha do tempo preliminar e defender a próxima ação de coleta sem comprometer o processo.

|                    |                    |                          |
|--------------------|--------------------|--------------------------|
| Duração 52 minutos | Organização duplas | Entrega um PDF por dupla |
|--------------------|--------------------|--------------------------|

## Objetivos

- Distinguir observação, hipótese e conclusão ao analisar registros.
- Relacionar eventos a impacto em TI, OT e safety.
- Justificar uma próxima coleta ou contenção com evidência e restrições.

## Pré-requisitos e recursos

- Página MkDocs A01 consultável durante a atividade.
- Este roteiro e o pacote de evidências nele contido.
- Editor de texto ou papel para organizar a linha do tempo.
- Juice Shop local é opcional; nenhuma exploração é necessária nesta aula.

### ATENÇÃO

Escopo autorizado: somente os dados fictícios deste roteiro e o ambiente da disciplina. Não teste endereços externos. Pare se o laboratório apresentar efeito fora do cenário e avise o professor.

## Hipótese inicial

Antes de continuar, registre: (1) a causa mais provável; (2) por que ela explicaria a parada; (3) qual evidência poderia refutá-la.

Hipótese: \_\_\_\_\_

Evidência necessária: \_\_\_\_\_

Etapa 1 — Ordenar sem interpretar (10 min)

Os relógios foram sincronizados para esta atividade. Ordene os registros e marque cada linha como evento de autenticação, comunicação, processo ou resposta.

| Horário  | Fonte      | Registro                              |
|----------|------------|---------------------------------------|
| 09:17:08 | HMI-01     | alarm_ack ALM-204                     |
| 09:16:52 | HMI-01     | login_success operador_turno          |
| 09:17:05 | LINE-01    | state_change RUN → STOP               |
| 09:17:03 | PLC-01     | comm_timeout 3200 ms                  |
| 09:18:11 | NET-SENSOR | flux HMI-01 → PLC-01<br>restabelecido |

EVIDÊNCIA

Entregue uma linha do tempo ordenada. Para cada evento, escreva uma frase dizendo o que ele mostra diretamente — sem atribuir causa ou autoria.

Etapa 2 — Comparar hipóteses (15 min)

Compare pelo menos duas explicações. Uma boa hipótese explica vários eventos e declara o que ainda não consegue explicar.

| Hipótese                                 | Evidência favorável | Lacuna ou contradição |
|------------------------------------------|---------------------|-----------------------|
| Falha de comunicação                     |                     |                       |
| Ação indevida ou credencial comprometida |                     |                       |

PISTA

Login anterior ao evento não prova que a pessoa autenticada causou a parada. Sequência temporal é necessária para correlação, mas não basta para causalidade.

Etapa 3 — Decidir a próxima coleta (15 min)

Escolha uma ação: preservar os logs da HMI; capturar tráfego entre HMI e PLC; consultar o histórico de alarmes; ou isolar a HMI. Compare benefício, risco operacional e reversibilidade.

| Opção          | Melhor uso | Evidência gerada | Limitação/risco |
|----------------|------------|------------------|-----------------|
| Preservar logs |            |                  |                 |

| Opção                | Melhor uso | Evidência gerada | Limitação/risco |
|----------------------|------------|------------------|-----------------|
| Capturar tráfego     |            |                  |                 |
| Histórico de alarmes |            |                  |                 |
| Isolar HMI           |            |                  |                 |

## DECISÃO

Registre a ação escolhida, a autorização necessária, o critério de parada e por que ela preserva disponibilidade e safety.

## Etapa 4 — Validar e comunicar (12 min)

- Revise se a conclusão excede o que as evidências sustentam.
- Mantenha uma hipótese alternativa plausível.
- Indique qual novo resultado confirmaria ou enfraqueceria a hipótese principal.
- Sanitize a entrega: não inclua credenciais, tokens, IPs públicos ou dados pessoais.

## Entrega

Envie no Google Classroom um PDF chamado A01-dupla-NN.pdf contendo: hipótese inicial; linha do tempo; tabela de hipóteses; decisão justificada; e uma reflexão de até cinco linhas.

## Critérios de sucesso

| Critério       | Atendeu                                  | Parcial                                   |
|----------------|------------------------------------------|-------------------------------------------|
| Linha do tempo | Ordenada; fatos separados de inferências | Há ordem, mas mistura fato e inferência   |
| Hipóteses      | Duas explicações comparadas com lacunas  | Só uma hipótese ou comparação superficial |
| Decisão        | Considera evidência, risco e safety      | Justificativa incompleta                  |
| Comunicação    | Limites e próxima validação explícitos   | Conclusão sem limites claros              |

## Limpeza e encerramento

- Feche os arquivos do pacote e descarte anotações com dados não sanitizados.
- Se o Juice Shop local foi aberto, encerre o processo ou container.

- Confirme que nenhum serviço vulnerável ficou acessível fora do laboratório.

## **Extensão opcional**

Crie um evento adicional que diferenciaria as duas hipóteses sem revelar a resposta. Troque com outra dupla e avalie se o novo dado realmente muda a decisão.

## **Transferência**

Em um hospital, edifício inteligente ou sistema de transporte, qual consequência alteraria a prioridade entre preservar evidência e estabilizar o processo?

## **Fontes oficiais**

- NIST Cybersecurity Framework 2.0 — <https://www.nist.gov/cyberframework>
- NIST SP 800-82 Rev. 3 — <https://csrc.nist.gov/pubs/sp/800/82/r3/final>